

Lab 01 – Where Is the Industrial Security? – Solutions

Industrial Security (Bachelor)

• Maps to Section 01

• 30 min

LAB 01

🎯 Goal

Lecturer / TA reference: sample completed deliverables, model answers to the open-ended questions, and a grading rubric for the paper-only observation lab.

✅ Step 1 – Sample inventory table

Accept any eight devices the student can plausibly point to. The mix below shows the three classes the rubric expects to see.

System	Class	Worst-case consequence	Owner / maintainer
Lecture-hall projector	IT	Lecture cancelled; image spoofing	Faculty AV / IT services
Wi-Fi access point	IT	Credential theft, lateral access	University IT
Badge reader at lab door	IIoT	Unauthorised physical entry	Facility mgmt + integrator
Elevator controller	OT	Trapped passengers; injury	Building owner + OEM contract
Building HVAC (AHU)	OT	Loss of conditioning; mould; downtime	Facility mgmt
Fire alarm panel	OT	Missed/false evacuation; life safety	Facility mgmt (regulated)
Smart electricity sub-meter	IIoT	Billing fraud; grid-side data leak	DSO / utility
Vending machine (telemetry)	IIoT	Cash loss; pivot into payment net	Vendor (operator-owned hw)

✅ Step 1 – Model IT / OT / IIoT calls

Decision rule to apply when grading: *IT* = handles data, no physical actuation; *OT* = controls a physical process, often with safety/availability priority; *IIoT* = network-connected device that bridges both (telemetry or remote control over IP).

- **Projector / Wi-Fi AP – IT.** Pure information assets; CIA priority $C > I > A$.
- **Elevator, HVAC, fire panel – OT.** Real-time control of a physical process; priority $A > I > C$; safety-relevant.
- **Badge reader, smart meter, telemetry vending – IIoT.** OT-style function (door release, metering) reachable over IP; both attack surfaces apply.

A defensible alternative classification with sound reasoning earns full marks – this is a discussion lab, not a quiz.

✅ Step 2 – Stakeholder map (example: elevator)

Expected nodes and the CIA priority each stakeholder pushes: *Operator* (building manager) – **Availability**; *Owner* (university) – **Availability** + **Integrity** (liability); *Integrator* (lift service company) – **Integrity** (safe firmware, signed updates); *Vendor / OEM* – **Integrity** + **Confidentiality** (IP protection); *Regulator* (TUV / national lift inspectorate) – **Safety & Integrity** via certified configuration. Award the point if the diagram shows at least four of

these five roles with at least one CIA label per role.

✓ Step 3 – Reflection, model answer

Expected line of argument: the *operator* (or facility manager) will push back hardest against a control that interrupts normal operation – e.g. a forced reboot for patching, an MFA prompt on an HMI, or a network segmentation that blocks a vendor’s remote-support tunnel. This is *legitimate* because their KPI is uptime and safety of the running process; an unplanned stop on an elevator, boiler or production line can cause injury, regulatory breach, or six-figure losses far exceeding the residual cyber risk the control was meant to mitigate. Good answers note that the fix is not to overrule the operator but to schedule the control inside a maintenance window and to involve the integrator/vendor early.

✓ Discussion points to surface

- CIA triad inverts between IT (C-I-A) and OT (A-I-C).
- “Smart” anything is usually IIoT – so the attack surface is doubled, not halved.
- Ownership is rarely the same as operation: vendor remote access is the recurring blind spot.
- Safety regulator > security policy when the two collide (fire panel, lift).

📖 Grading rubric

Total 10 pts; pass mark 5.

- **Step 1 inventory (4 pts):** 8 distinct systems (2), correct class with one-line reasoning (1), worst-case + owner filled in (1).
- **Step 2 stakeholder map (3 pts):** ≥ 4 stakeholder roles (1), CIA label per role (1), arrows/relationships shown (1).
- **Step 3 reflection (2 pts):** identifies the right stakeholder (1), gives a legitimate operational reason, not just “they are lazy” (1).
- **Hygiene (1 pt):** legible, no device names photographed/scanned (warnbox respected).

Auto-fail: any evidence the student probed, photographed, or network-scanned a real device on campus – re-issue the lab.